

Gap Assesment Report: Skybridge Digital

Subcategory	Current	Target	Gap Severity	Recommended Action	Owner	Target Date
GV.OC-03	Partial	Centralized compliance requirements register	High	Create and maintain a centralized register of legal, regulatory, and contractual requirements.	Compliance Manager	Q4 2026
GV.RM-01	Partial	Formal risk appetite and tolerance	High	Obtain leadership approval for enterprise cybersecurity risk appetite and tolerance levels.	CISO	Q4 2026
GV.RR-01	Partial	Clearly documented cybersecurity responsibilities	High	Develop and approve a RACI matrix covering security, IT, cloud, business units, and vendors.	CISO	Q4 2026
GV.PO-01	Partial	Comprehensive security policy framework	Medium	Review and standardize security policies across cloud, applications, remote work, and third-party environments.	CISO	Q1 2027

GV.OV-01	Not Implemented	Quarterly cybersecurity strategy review	High	Establish a formal quarterly cybersecurity strategy and risk review process for senior leadership.	CISO	Q4 2026
GV.SC-02	Partial	Formal third-party risk classification	High	Implement a vendor risk-tiering methodology based on criticality, data access, and business impact.	Third-Party Risk Manager	Q4 2026
ID.AM-01	Partial	Complete enterprise asset inventory	High	Consolidate asset discovery across offices, remote endpoints, AWS, Azure, and other infrastructure.	IT Asset Manager	Q1 2027

ID.AM-02	Partial	Centralized software and application inventory	Medium	Establish an authorized software and application inventory with regular reconciliation.	IT Operations Manager	Q1 2027
ID.AM-03	Partial	Documented critical data flows	High	Map data flows for the payment platform, public-facing applications, cloud environments, and critical vendors.	Data Protection Officer	Q1 2027
ID.RA-01	Partial	Continuous vulnerability discovery	Critical	Expand vulnerability scanning across cloud infrastructure, endpoints, applications, and internet-facing assets.	Vulnerability Management Lead	Q3 2026

ID.RA-04	Partial	Standardized enterprise risk scoring	High	Implement a consistent likelihood-and-impact risk scoring methodology.	Enterprise Risk Manager	Q4 2026
ID.RA-05	Partial	Centralized risk register	High	Implement a centralized risk register with risk owners, treatment plans, deadlines, and acceptance decisions.	Enterprise Risk Manager	Q4 2026
PR.AA-01	Implemented	Centralized identity lifecycle management	Medium	Integrate all relevant employees, contractors, and third parties into a consistent identity lifecycle process.	IAM Manager	Q4 2026

PR.AA-03	Partial	Quarterly critical access reviews	High	Establish quarterly reviews for privileged accounts and access to critical systems.	IAM Manager	Q3 2026
PR.AA-05	Partial	MFA for all critical access	Critical	Enforce MFA across cloud platforms, M365, remote access, privileged accounts, and critical applications.	IAM Manager	Q3 2026
PR.AT-01	Partial	Mandatory measurable security awareness	Medium	Implement mandatory training with completion tracking and periodic effectiveness testing.	Security Awareness Manager	Q4 2026

PR.DS-01	Partial	Encryption at rest for sensitive data	High	Establish encryption standards and remediate unencrypted sensitive data stores.	Data Security Manager	Q1 2027
PR.DS-02	Partial	Strong encryption in transit	High	Standardize encryption requirements for sensitive data transmitted across internal networks and third parties.	Security Architecture Manager	Q4 2026
PR.PS-01	Partial	Secure configuration baselines	High	Develop and enforce secure configuration baselines for AWS, Azure, M365, endpoints, and servers.	Security Engineering Manager	Q1 2027

PR.PS-04	Partial	Risk-based patching with SLAs	Critical	Define risk-based patching timelines and monitor remediation against approved SLAs.	Vulnerability Management Lead	Q3 2026
DE.CM-01	Partial	Centralized network and cloud monitoring	High	Expand security monitoring coverage across AWS, Azure, corporate networks, and critical infrastructure.	SOC Manager	Q4 2026
DE.CM-03	Partial	Centralized user and administrator monitoring	High	Centralize logging and monitoring of privileged and high-risk user activity.	SOC Manager	Q4 2026

DE.CM-09	Partial	Continuous cloud and application monitoring	Critical	Implement continuous monitoring for public-facing applications and critical cloud workloads.	Cloud Security Manager	Q3 2026
DE.AE-02	Partial	Automated cross-environment event correlation	High	Integrate security events from AWS, Azure, M365, endpoints, and applications into centralized analysis.	SOC Manager	Q1 2027
DE.AE-03	Partial	Centralized security event aggregation	High	Improve centralized collection and retention of security logs from critical systems.	SIEM Manager	Q4 2026

RS.MA-01	Partial	Tested incident response procedures	Critical	Develop and conduct tabletop exercises for ransomware, cloud compromise, payment platform compromise, and major outages.	Incident Response Manager	Q3 2026
RS.CO-02	Partial	Standardized incident communications	High	Define communication procedures for executives, customers, regulators, employees, and third parties.	CISO / Communications Director	Q4 2026
RS.AN-03	Partial	Documented root-cause analysis	Medium	Establish a formal post-incident review and lessons-learned process for significant incidents.	Incident Response Manager	Q4 2026

RS.MI-01	Partial	Tested containment and eradication playbooks	Critical	Develop and test response playbooks for ransomware, compromised accounts, cloud attacks, and application compromise.	Incident Response Manager	Q3 2026
RC.RP-01	Partial	Tested recovery procedures	Critical	Conduct regular recovery testing for payment services, critical applications, cloud infrastructure, and M365.	Business Continuity Manager	Q3 2026
RC.CO-02	Partial	Formal recovery communications	Medium	Establish defined communication responsibilities and escalation paths during service recovery.	Business Continuity Manager	Q4 2026